THOMSON COURSE TECHNOLOGY

Guide to Network Defense and Countermeasures Third Edition

Chapter 11

VPN Concepts

Objectives

- Explain basic VPN concepts
- Describe encapsulation in VPNs
- Describe encryption in VPNs
- Describe authentication in VPNs
- Explain considerations for planning VPN deployments
- Describe options for VPN configurations
- Explain ways to adjust packet-filtering rules for VPNs
- Describe ways to review VPN policies and procedures

© Cengage Learning 2014

Understanding VPN Concepts

- Virtual Private Network (VPN) enables computers to
  - Communicate securely over insecure channels
  - Exchange private encrypted messages that others cannot decipher
- Virtual network connection
  - Uses the Internet to establish a secure connection
    - Secure **tunnel**
  - Extends an organization's network
- Endpoints
  - Specified computers, users, or network gateways

© Cengage Learning 2014

Establishing Connections with a VPN

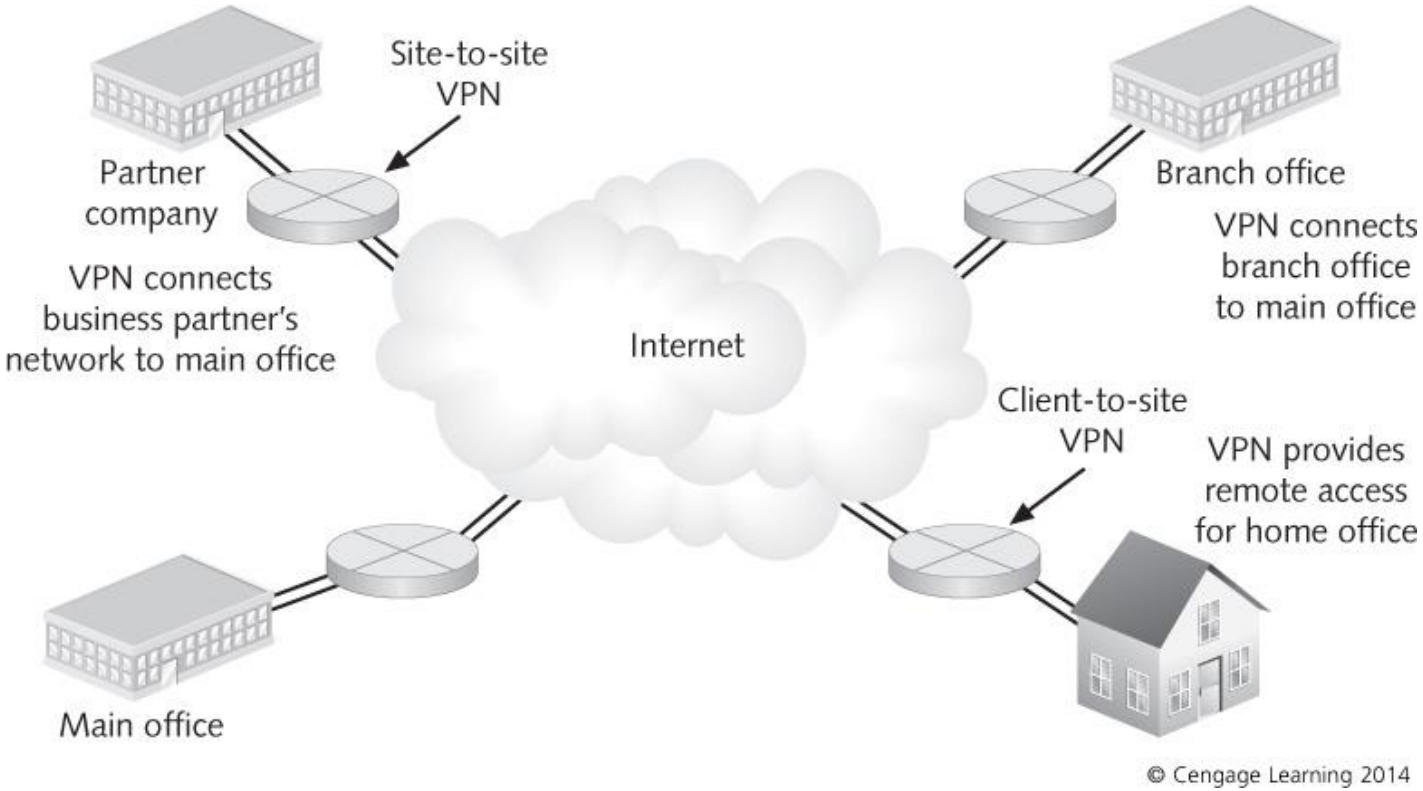

Figure 11-1 Establishing connections with a VPN

VPN Components, Part 1

- Essential elements of VPNs
  - VPN server or host
    - Configured to accept connections from clients
  - VPN client or guest
    - Endpoints connecting to a VPN
  - Tunnel
    - Connection through which data is sent
  - VPN protocols
    - Sets of standardized communication settings
    - Used to encrypt data sent along the VPN

© Cengage Learning 2014

VPN Components, Part 2

- Can set up two types of VPNs
  - Site-to-site VPN (gateway-to-gateway VPN)
    - Links two or more networks
  - Client-to-site VPN (remote access VPN)
    - Makes a network accessible to users who need remote access

© Cengage Learning 2014

Types of VPNs, Part 1

- Hardware VPNs
  - Connect one gateway to another
  - Routers at each network gateway that encrypt and decrypt packets
  - **VPN appliance**
    - Designed to serve as VPN endpoint and join LANs
  - Benefits
    - Scalable
    - Better security

© Cengage Learning 2014

VPN Appliance Creating Secure Connection Between LANs

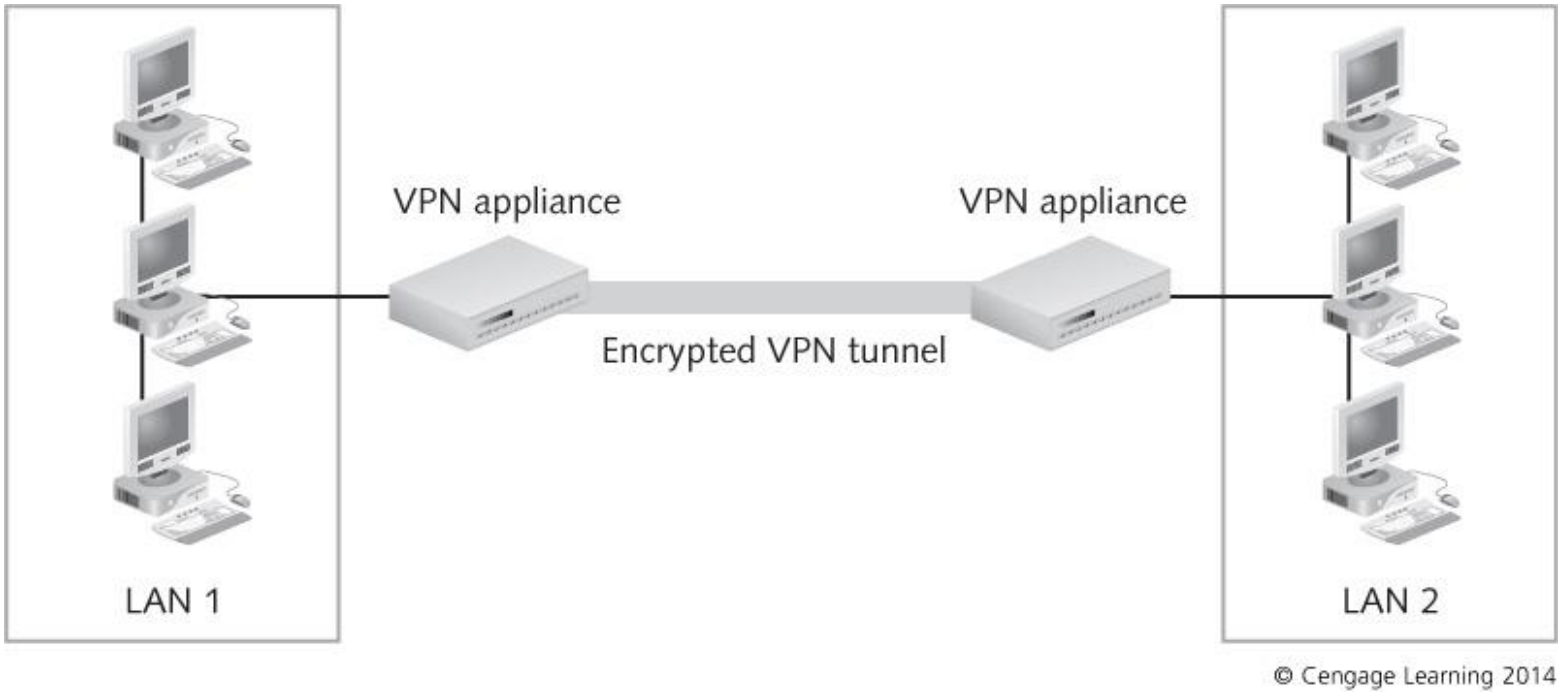

Figure 11-2 VPN appliance creates secure connections between two or more LANs

Types of VPNs, Part 2

- Hardware VPNs (cont'd)
  - Security industry is moving toward integrated solutions
  - Unified Threat Management (UTM) – describes how to create a single product suite by integrating firewalls, intrusion detection and prevention, antivirus, e-mail, and communication security
    - Also VPNs, secure remote access, and authentication
  - Advantages of integrated security
    - Cost, interoperability, and easier management
  - Drawback: single point of failure

© Cengage Learning 2014

Types of VPNs, Part 3

- Software-based VPNs
  - Most are integrated with firewalls
  - Increase network security
    - Integrated with functions that a firewall already performs such as packet-filtering and NAT
  - Appropriate when participating networks use different routers and firewalls
  - Offers flexibility
    - Can filter traffic based on domain name, protocol, or IP address
  - Drawback
    - Configuring and using can be complex

© Cengage Learning 2014

Evaluating Business Needs for VPNs, Part 1

- Reasons for establishing a VPN:
  - Need to follow a budget while maintaining security
  - Secure remote access for employees
  - Need for a secure means of connection for partners, suppliers, contractors, and others outside the company
- Security policy should be reviewed
- Analyze existing infrastructure to determine how and where to place a VPN
- Determine whether to use a software or hardware appliance, server, firewall, or router to do the job

© Cengage Learning 2014

Evaluating Business Needs for VPNs, Part 2

- A secure VPN design should address the following:
  - Secure connectivity
  - Encryption
  - Availability
  - Authentication
  - Secure management
  - Reliability
  - Scalability
  - Performance

© Cengage Learning 2014

Advantages and Disadvantages of VPNs

Advantages	Disadvantages
Far less expensive than leased lines	Can be complex to configure
Many elements working together provide strong security	Can result in slower data transfer rates than a leased line
Standards and protocols used in VPNs are well developed and widely used	Depends on the often unpredictable Internet; if your ISP or other parts of the Internet go down, your VPN goes down
Can result in less overall complexity in an organization's network	Requires administrators to install VPN client software on remote computers
Can make use of a company's existing broadband connection	VPN hardware and software from different vendors might prove incompatible because they use different protocols

Table 11-1 Advantages and disadvantages of VPNs

The Three VPN Core Activities

- VPNS provide a high level of security because they perform a core set of activities:
  - Encapsulation
  - Encryption
  - Authentication

© Cengage Learning 2014

Encapsulation

- Encapsulation
  - Encloses a packet within another
    - That has different IP source and destination
  - Protects integrity of the data
    - By hiding the data packets' source and destination information
  - VPN encapsulates data packets in packets that use the VPN gateway's source and destination addresses
  - When VPN tunnel is in place, source and destination IP addresses can be private reserved blocks that are not routable over the internet

© Cengage Learning 2014

Encapsulating Data to Conceal Source and Destination Information

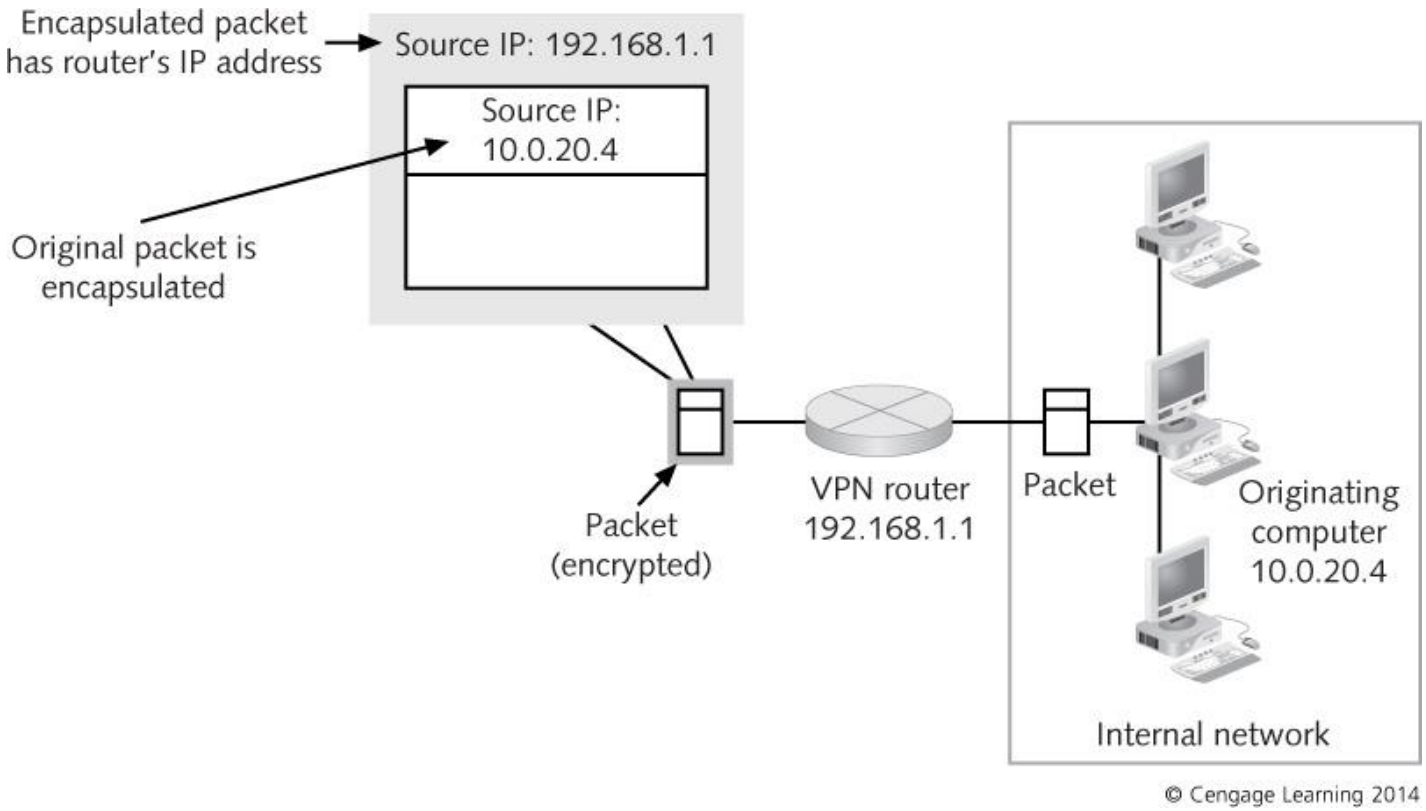

Figure 11-3 Encapsulating data to conceal source and destination information

Understanding Tunneling Protocols, Part 1

- When configuring a VPN you need to choose the protocol you want to use
- Point-to-Point Tunneling Protocol (PPTP)
  - Used when you need to dial in to a server with a modem connection
    - On a computer using an older OS version
  - Encapsulates TCP/IP packets
  - Uses Microsoft Point-to-Point Encryption (MPPE)
    - Encrypt data that passes between the remote computer and the remote access server
  - PPTP should only be used in trusted networks where security is addressed by other means

© Cengage Learning 2014

Understanding Tunneling Protocols, Part 2

- Layer 2 Tunneling Protocol (L2TP)
  - Based on two older PPP tunneling protocols
  - Endpoints of an L2TP tunnel are called
    - L2TP Access Concentrator (LAC)
    - L2TP Network Server (LNS)
  - Provides better security through IPsec
  - IPsec enables L2TP to perform
    - Authentication
    - Encapsulation
    - Encryption
  - No information about the internal network can be gained

© Cengage Learning 2014

Understanding Tunneling Protocols, Part 3

- Generic Routing Encapsulation (GRE)
  - Tunneling protocol that can encapsulate a variety of Network layer packets inside IP packets
  - Encapsulates actual packet inside a GRE packet, which is then encapsulated in an arbitrary transport protocol
  - Stateless protocol
    - An endpoint might not be able to detect a service provider
  - Uses IP protocol 47 and native IPv4 routing

© Cengage Learning 2014

Understanding IPsec/IKE, Part 1

- Internet Protocol Security (IPsec)
  - Set of standard procedures
  - Developed by the Internet Engineering Task Force (IETF)
  - Enables secure communications on the Internet
- IPsec has become the standard for many reasons:
  - Works at layer 3
  - Can encrypt an entire TCP/IP packet
  - Originally developed for use with IPv6
  - Provides authentication of source and destination computers

© Cengage Learning 2014

Understanding IPsec/IKE, Part 2

- Widely supported by a variety of VPN hardware and software devices
- Security Association (SA)
  - Relationship between two or more entities
  - Describes how they will use security services to communicate
  - Used by IPsec to track all the particulars of a communication session
  - SAs are unidirectional

© Cengage Learning 2014

IPsec Components, Part 1

- IPsec Components
  - Internet Security Association Key Management Protocol (ISAKMP)
  - Internet Key Exchange (IKE)
  - Oakley
  - IPsecurity Policy Management
  - IPsec Driver
- IPsec core components – protect packets exchanged in the VPN
  - Authentication Header (AH)
  - Encapsulation Security Payload (ESP)

© Cengage Learning 2014

IPsec Components, Part 2

- Authentication Header (AH)
  - Provides authentication of packets and ensures data integrity
    - Packets are signed with a digital signature
  - Adds a header calculated by the values in the packet
    - Creating a message digest of the packet
  - Security is achieved by calculating the values with a hashing algorithm and a key known only to entities in transaction
    - Only authorized entities know the key
    - Only they know how to run the algorithm to see if data has been tampered with

© Cengage Learning 2014

IPsec Components, Part 3

- Authentication Header (AH)
  - Two IPsec modes: tunnel and transport
  - AH in tunnel mode
    - Authenticates the entire original header
    - Places a new header at the front of the original packet
  - AH in transport mode
    - Authenticates the data and the original IP header

© Cengage Learning 2014

AH Message Exchange

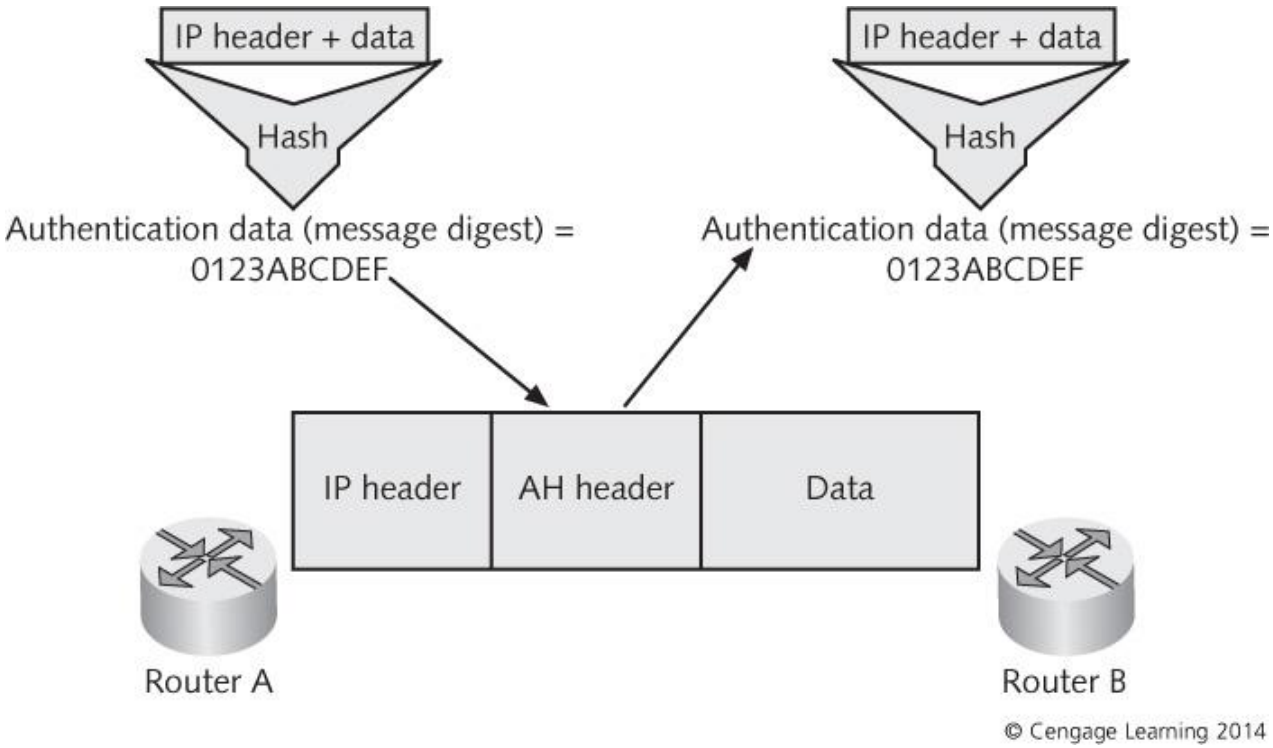

Figure 11-4 AH message exchange

AH in Tunnel and Transport Modes

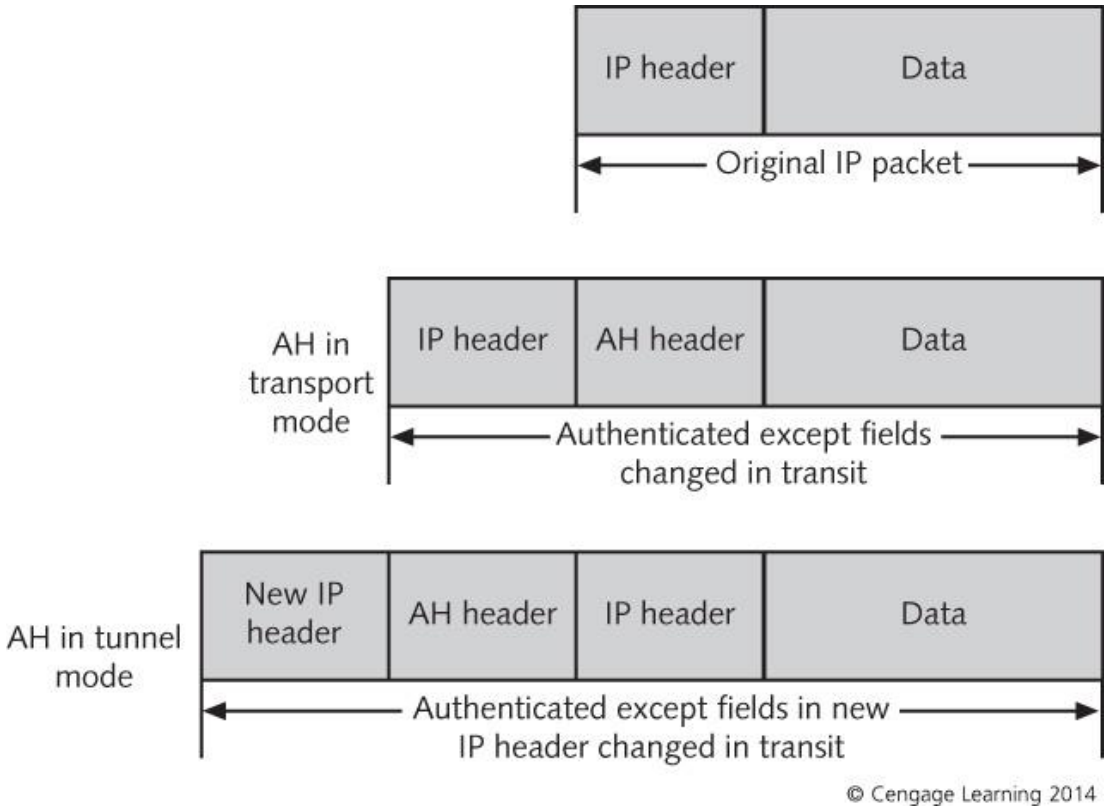

Figure 11-5 AH in tunnel and transport modes

IPsec Components, Part 4

- Encapsulation Security Payload (ESP)
  - Provides confidentiality for messages
  - Encrypts different parts of a TCP/IP packet
  - ESP in tunnel mode
    - Encrypts both the header and data part of each packet
    - Data cannot pass through a firewall using NAT
  - ESP in transport mode
    - Data can pass through a firewall
  - If the VPN is used with a firewall that performs NAT:
    - IPsec should be configured to work in transport mode

© Cengage Learning 2014

ESP in Tunnel and Transport Modes

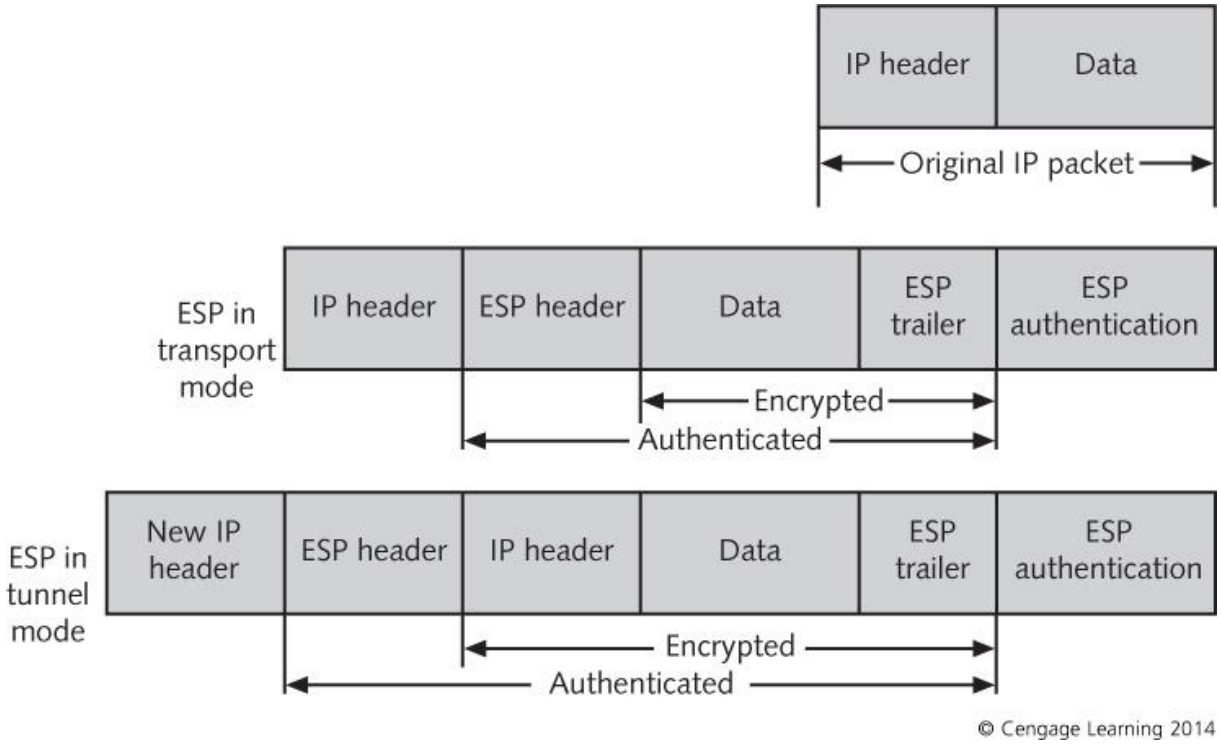

Figure 11-6 ESP in tunnel and transport modes

Encryption

- Encryption: process of rendering information unreadable by all but the intended recipient
  - Components
    - Key
    - Digital certificate
    - Certification Authority (CA)
  - Key exchange methods
    - Symmetric cryptography
    - Asymmetric cryptography
    - Internet Key Exchange

© Cengage Learning 2014

VPN Endpoints

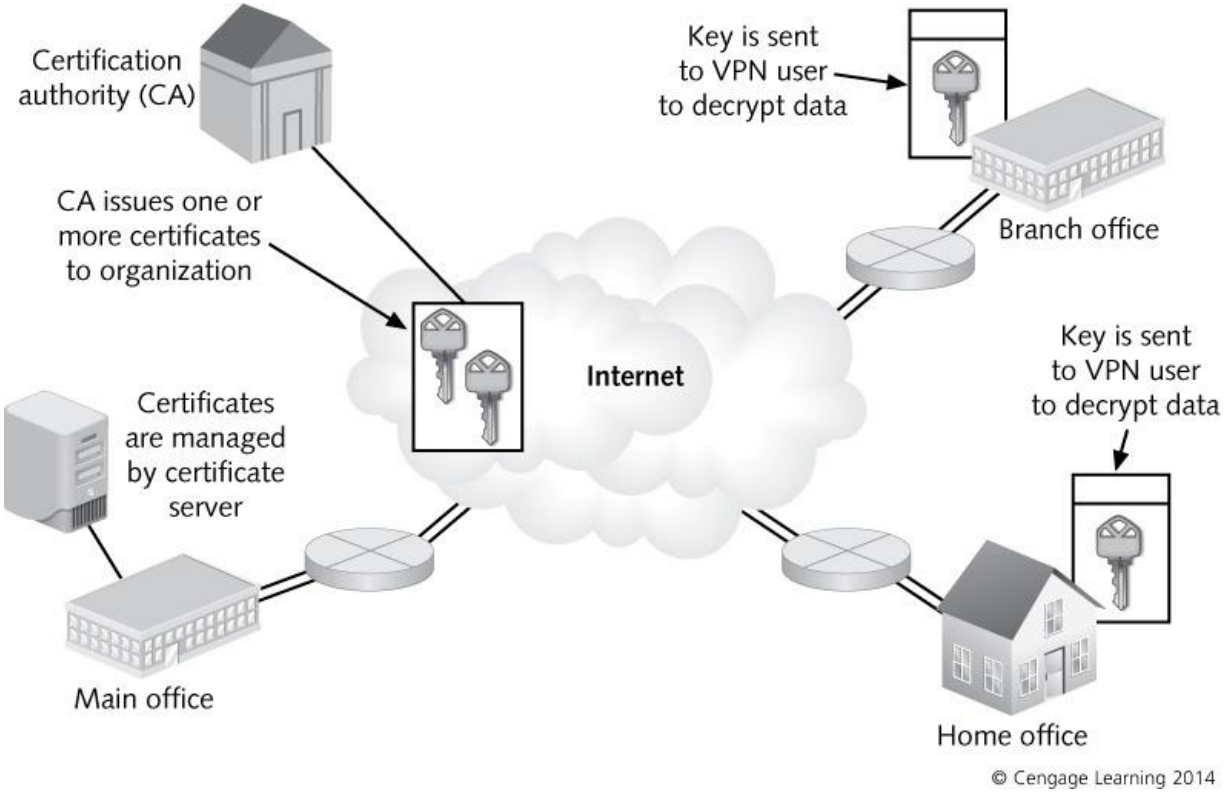

Figure 11-7 VPN endpoints encrypt and decrypt data by exchanging keys

Encryption Schemes, Part 1

- Triple Data Encryption Standard (3DES)
  - 3DES is a variation on Data Encryption Standard (DES)
  - DES is an older protocol standard that is not secure
  - 3DES is far more secure
    - Three separate 64-bit keys to process data
    - First key encrypts data, second key decrypts it, and third key encrypts it again
  - 3DES requires more time and computer resources than DES

© Cengage Learning 2014

Many VPNs Use 3DES Encryption

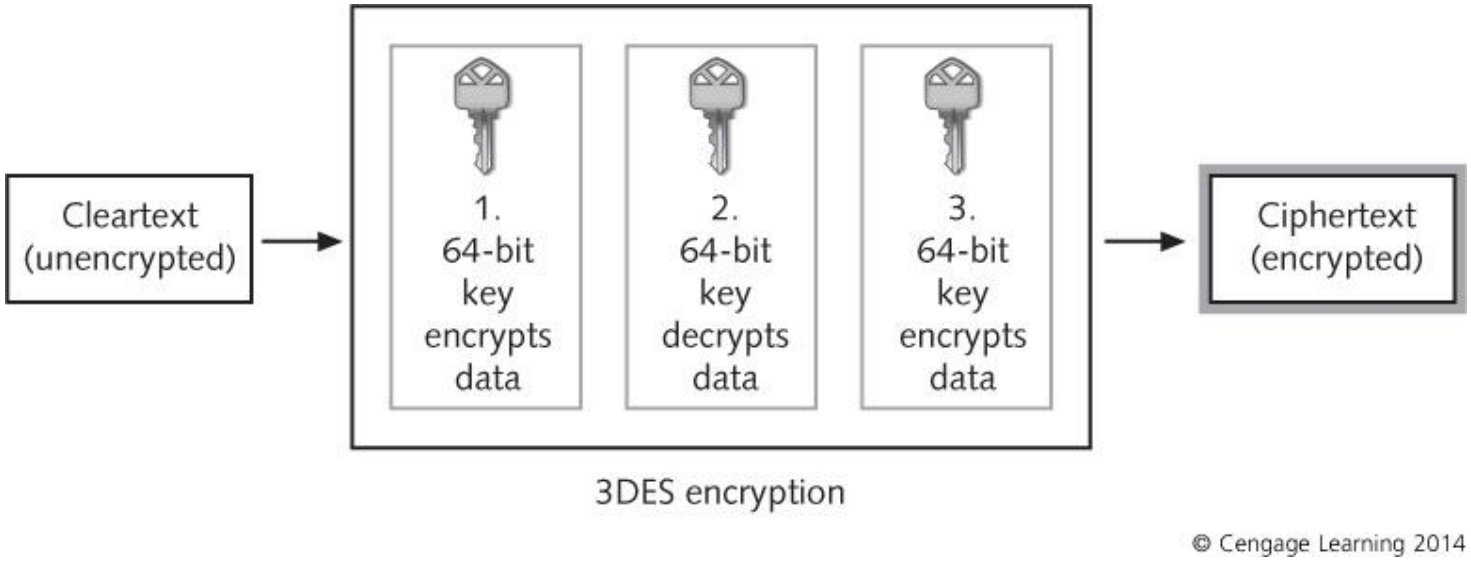

Figure 11-8 Many VPNs use 3DES encryption

Encryption Schemes, Part 2

- Advanced Encryption Standard (AES)
  - Developed to replace 3DES as the US government standard in 2002
  - Uses the Rijndael symmetric encryption algorithm
    - Specifies how to use 128-bit, 192-bit, or 256-bit keys on 128-bit, 192-bit, or 256-bit blocks
  - AES is a block cipher
    - Mathematical computations applied to blocks of data
    - Each application of the algorithm is called a round
    - Applies 10 rounds for 128-bit keys, 12 rounds for 192-bit keys, and 14 rounds for 256-bit keys

© Cengage Learning 2014

Encryption Schemes, Part 3

- Secure Sockets Layer (SSL)
  - Developed by Netscape Communications Corporation
  - Enables Web servers and browsers to exchange encrypted information
  - Characteristics
    - Uses public and private key encryption
    - Uses sockets method of communication
    - Operates at network layer (layer 3) of the OSI model
  - Widely used on the Web
    - VPNs that use SSL can support only data exchanged by Web-enabled applications
    - Unlikely to replace IPsec completely

© Cengage Learning 2014

Encryption Schemes, Part 4

- Secure Sockets Layer (SSL)
  - Steps
    - Client connects to Web server using SSL
    - Two machines arrange a “handshake” process
      - Client sends its preferences for encryption method, SSL version number, and a randomly generated number
    - Server responds with SSL version number, its own cipher preferences, and its digital certificate
    - Client verifies date and other information on the digital certificate
      - Client generates and send a “pre-master” code

© Cengage Learning 2014

Encryption Schemes, Part 5

- Secure Sockets Layer (SSL)
  - Steps (cont'd):
    - Server uses its private key to decode pre-master code
      - Generates a master secret key
      - Client and server use it to generate session keys
    - Server and client exchange messages saying handshake is completed
    - SSL session begins
  - SSL is a secure way to transmit data on the Internet
    - Can cause problems for firewalls that cannot interpret SSL data

© Cengage Learning 2014

Encryption Schemes, Part 6

- Transport Layer Security (TLS)
  - Similar to SSL in operation and design
  - TLS adds some improvements
    - Uses a hashed message authentication code (HMAC) that provides extra security by combining the hashing algorithm with a shared secret key
    - TLS splits input data in half, processes each half with a different hashing algorithm
      - Recombines data by using an exclusive OR (XOR) function

© Cengage Learning 2014

TLS Cryptography

Type of cipher	Cipher/algorithm
Public key (asymmetric)	Rivest-Shamir-Adleman (RSA), Diffie-Hellman, Digital Signature Algorithm (DSA)
Private key (symmetric)	Rivest Cipher (RC) 2, RC4, International Data Encryption Algorithm (IDEA), DES, 3DES, AES, and Camellia
Hashing algorithms	Message Digest (MD) 2, MD4, MD5, Secure Hash Algorithm (SHA), SHA-1, and SHA-256

Table 11-2 TLS cryptography

Authentication

- Authentication
  - Identifying a user or computer as authorized to access and use network resources
  - Types of authentication methods used in VPNs
    - IPsec
    - MS-CHAP
      - Both computers exchange authentication packets and authenticate one another
    - RADIUS
  - VPNs use digital certificates to authenticate users

© Cengage Learning 2014

VPN Core Activities

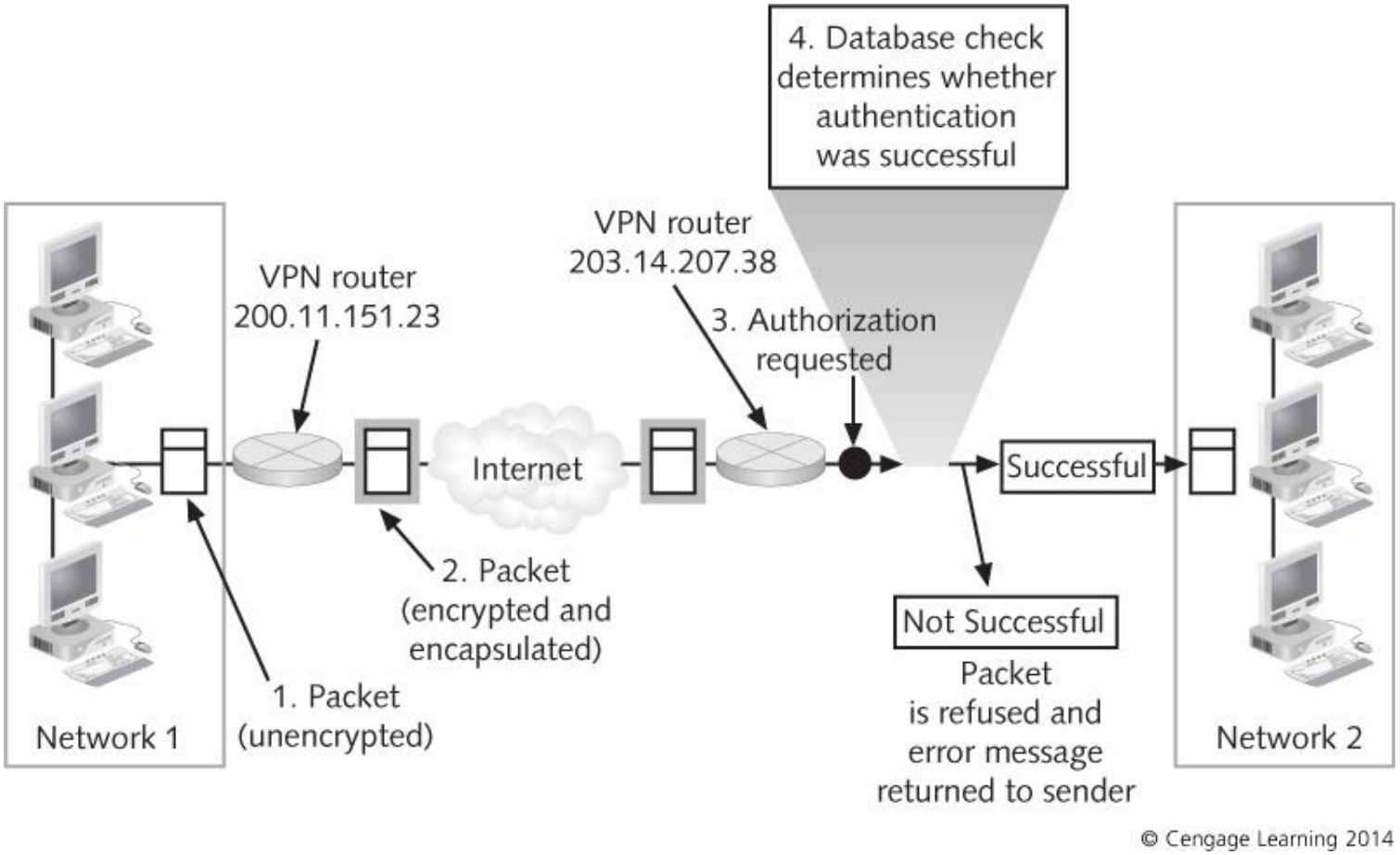

Figure 11-9 VPN core activities

Kerberos, Part 1

- Authentication system
  - Developed at the Massachusetts Institute of Technology (MIT)
- Authenticates the identity of network users
  - Authentication by assertion
  - Computer that connects to a server and requests services acts on behalf of an approved user

© Cengage Learning 2014

The Kerberos Authentication Process

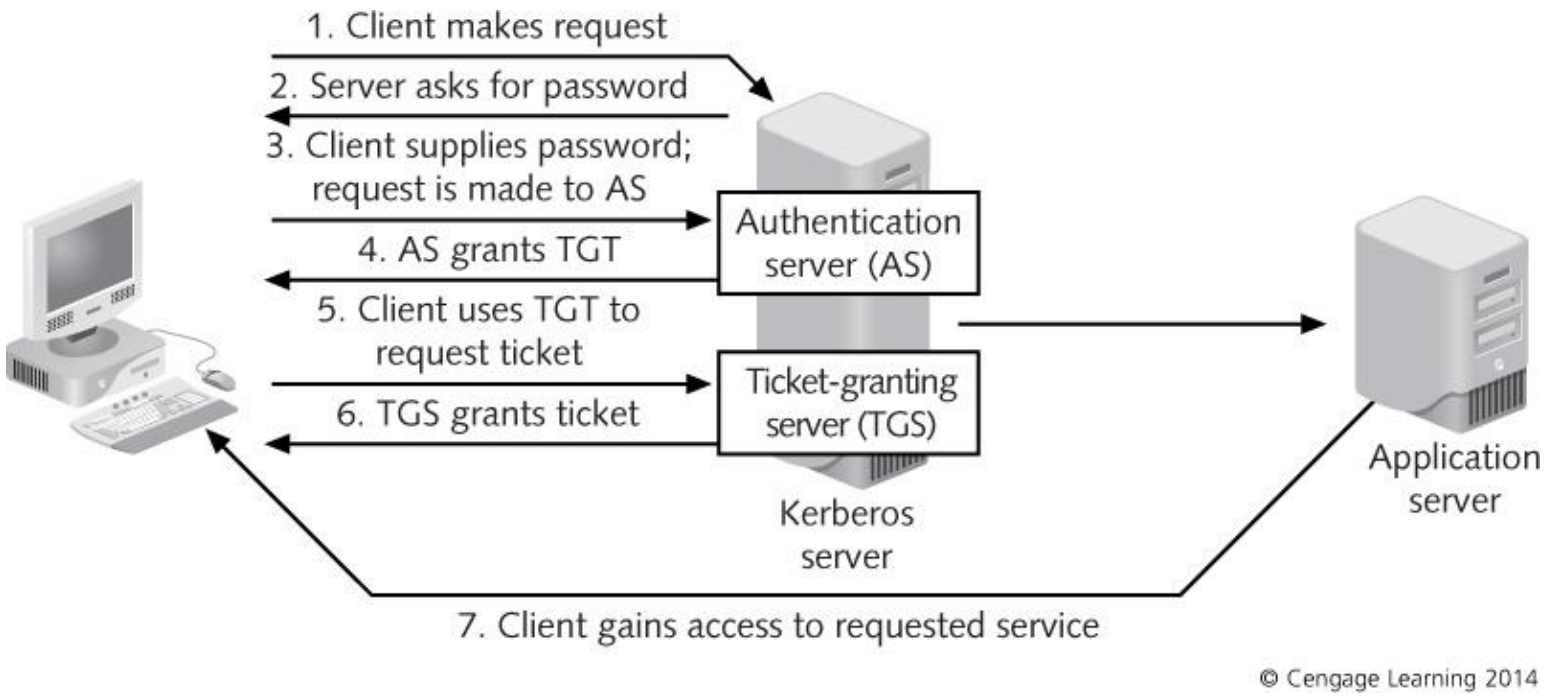

Figure 11-10 The Kerberos authentication process

Kerberos, Part 2

- Advantages
  - Passwords are not stored on the system
    - They cannot be intercepted
  - Has a lower “network overhead” than a Public Key Infrastructure (PKI)
  - Useful for single sign-on (SSO)
- Disadvantages
  - AS (KDC) is a single point of failure for Kerberos
    - If it goes down and no backup servers can take over its role, no one can be authenticated

© Cengage Learning 2014

Examining VPN Design and Architecture

- VPN topology
  - How components in a network are connected
  - Determines how gateways, networks, and clients are related to each other
  - Corresponds to the basic physical and logical topologies of any network
  - Three basic topologies:
    - Mesh, star, and hybrid VPNs

© Cengage Learning 2014

Mesh Topology

- All participants in the VPN have Security Associations (SAs) with one another
- Types of mesh arrangements
  - Full mesh - Every subnetwork is connected to all other subnets in the VPN
    - Complex to manage
  - Partial mesh - Any subnet in the VPN may or may not be connected to the other subnets
    - Offers more flexibility

© Cengage Learning 2014

A Full-Mesh VPN Configuration

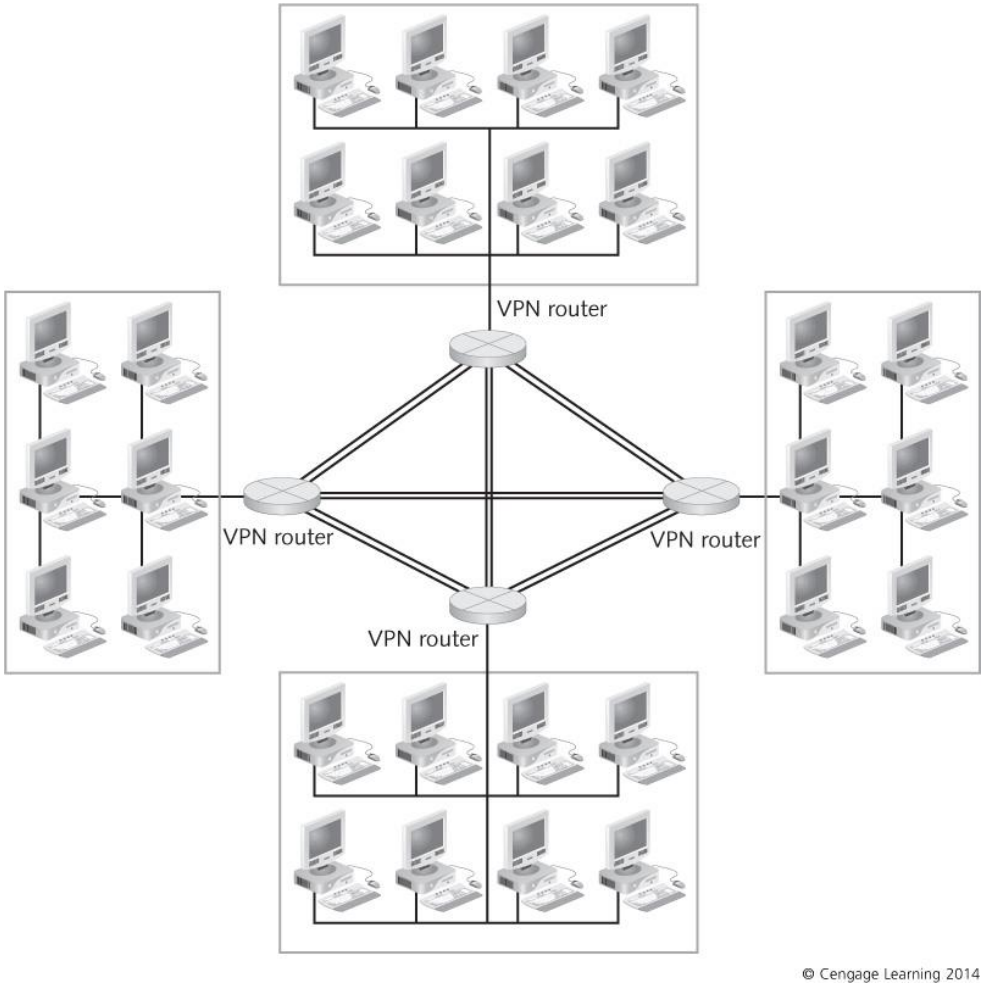

Figure 11-11 A full-mesh VPN configuration

Star Topology

- Also known as a hub-and-spoke configuration
- VPN gateway is the hub
  - Networks that participate in the VPN are called rim subnetworks
- Separate SAs are made between the hubs of each rim subnetwork
- Central VPN router is at organization's central office
- Any networks or computers that want to participate need to connect only to the central server

© Cengage Learning 2014

A Star VPN Configuration

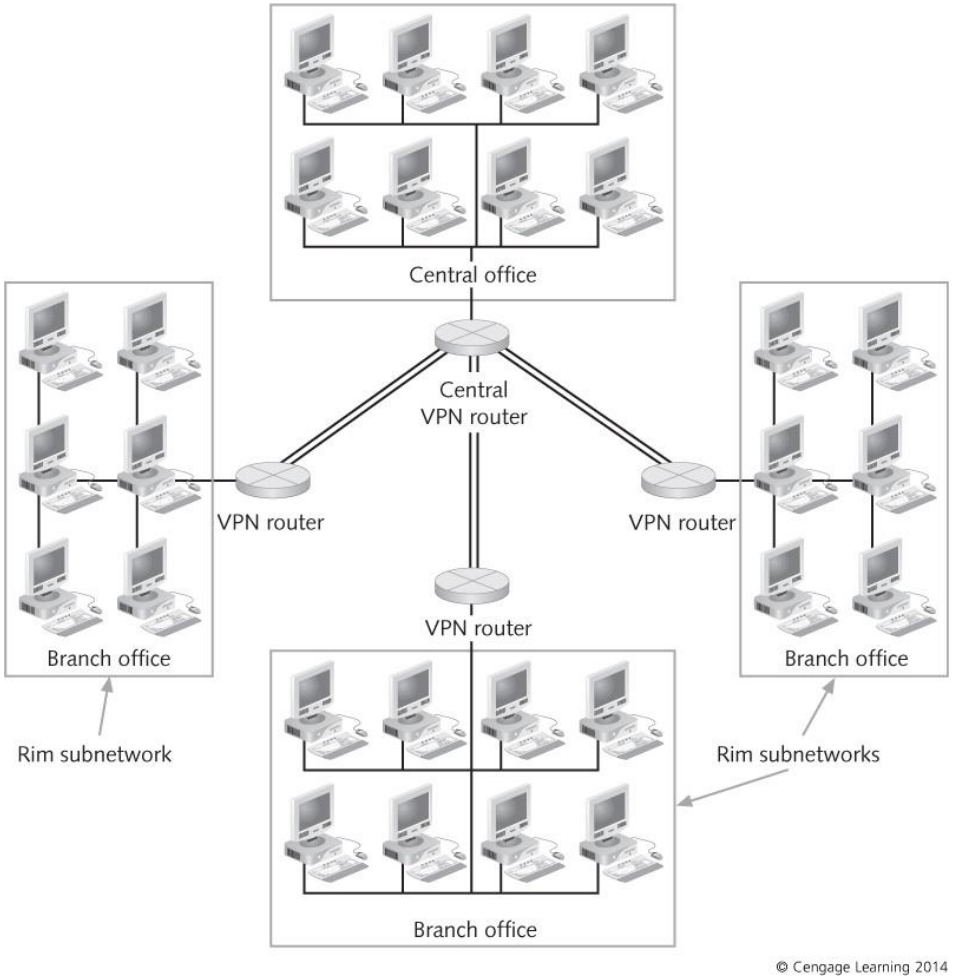

Figure 11-12 A star VPN configuration

Hybrid Topology

- Combines two different network topologies
- Central core uses a mesh topology
  - Mesh topologies tend to operate more efficiently
- Branch offices can be connected using a star topology
- Benefits from strengths of each topology
  - Scalability (of the star topology)
  - Speed (of the mesh configuration)

© Cengage Learning 2014

A Hybrid VPN Configuration

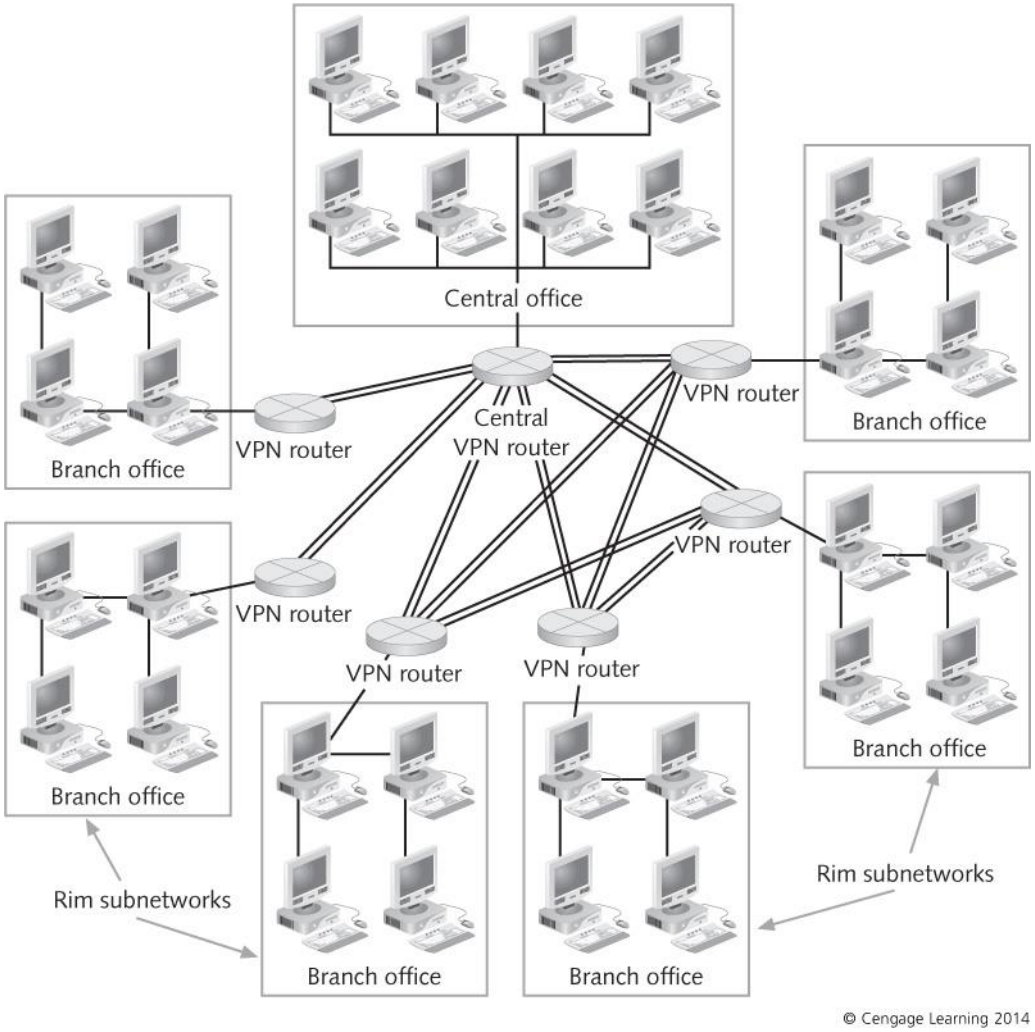

Figure 11-13 A hybrid VPN configuration

VPN Domains

- To set up a VPN, you need to define a **VPN domain**
  - Set of one or more computers that VPN hardware and software handle as a single entity
- Computers in a VPN domain use the VPN to communicate with another domain

© Cengage Learning 2014

Single and Multiple Entry Point Configurations, Part 1

- The decision whether to have single or multiple entry points
  - Depends on whether your network has a site-to-site or client-to-site VPN configuration
- Single entry point configuration
  - Typically used by small networks
  - All traffic to and from the network passes through a single gateway
  - Gateway must be a member of the VPN domain

© Cengage Learning 2014

Single and Multiple Entry Point Configurations, Part 2

- Multiple entry point configuration
  - Typically used by large organizations
  - Multiple gateways are used
    - Each with a VPN tunnel connecting a different location
  - Gateway must be excluded from the VPN domain
    - Otherwise all traffic will be encrypted reducing performance unnecessarily

© Cengage Learning 2014

Single and Multiple Entry Point Configurations, Part 3

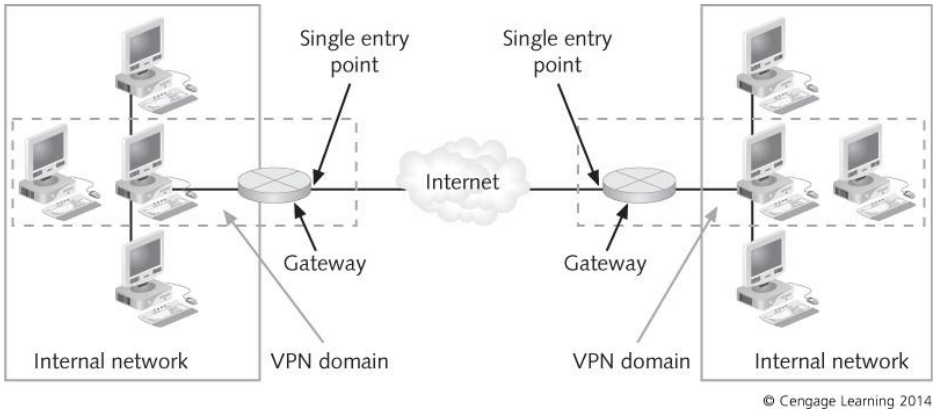

Figure 11-14 A single entry point configuration

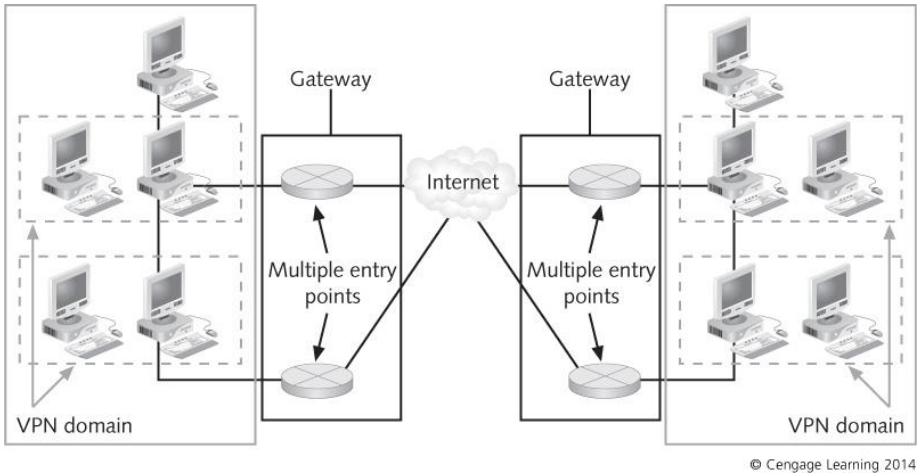

Figure 11-15 A multiple entry point configuration

Using VPNs with Firewalls, Part 1

- VPNs do not reduce the need for a firewall
  - Always use a firewall as part of VPN security design
- An option is to install VPN software on the firewall
  - Firewall allows outbound access to the Internet
  - Firewall prevents inbound access from the Internet
  - VPN service encrypts traffic to remote clients or networks

© Cengage Learning 2014

Using VPNs with Firewalls, Part 2

- Installing VPN software on the firewall
  - Advantages
    - Control all network access security from one server
    - Fewer computers to manage
    - Use the same tools for VPN and firewall
  - Disadvantages
    - Single point of failure
    - Must configure routes carefully
    - Incorrect configuration could allow traffic from Internet to get past security
    - Internet access and VPN traffic compete for resources on the server

© Cengage Learning 2014

Using VPNs with Firewalls, Part 3

- Set up VPN parallel to your firewall inside the DMZ
  - Advantages
    - No need to modify firewall settings to support VPN traffic
    - Configuration scales more easily
    - Can deal with congested servers
  - Disadvantages
    - VPN server is connected directly to the Internet
    - If VPN server becomes compromised, attacker will have direct access to your internal network
    - Cost of supporting a VPN increases with new servers

© Cengage Learning 2014

The VPN Server Parallel to a Firewall

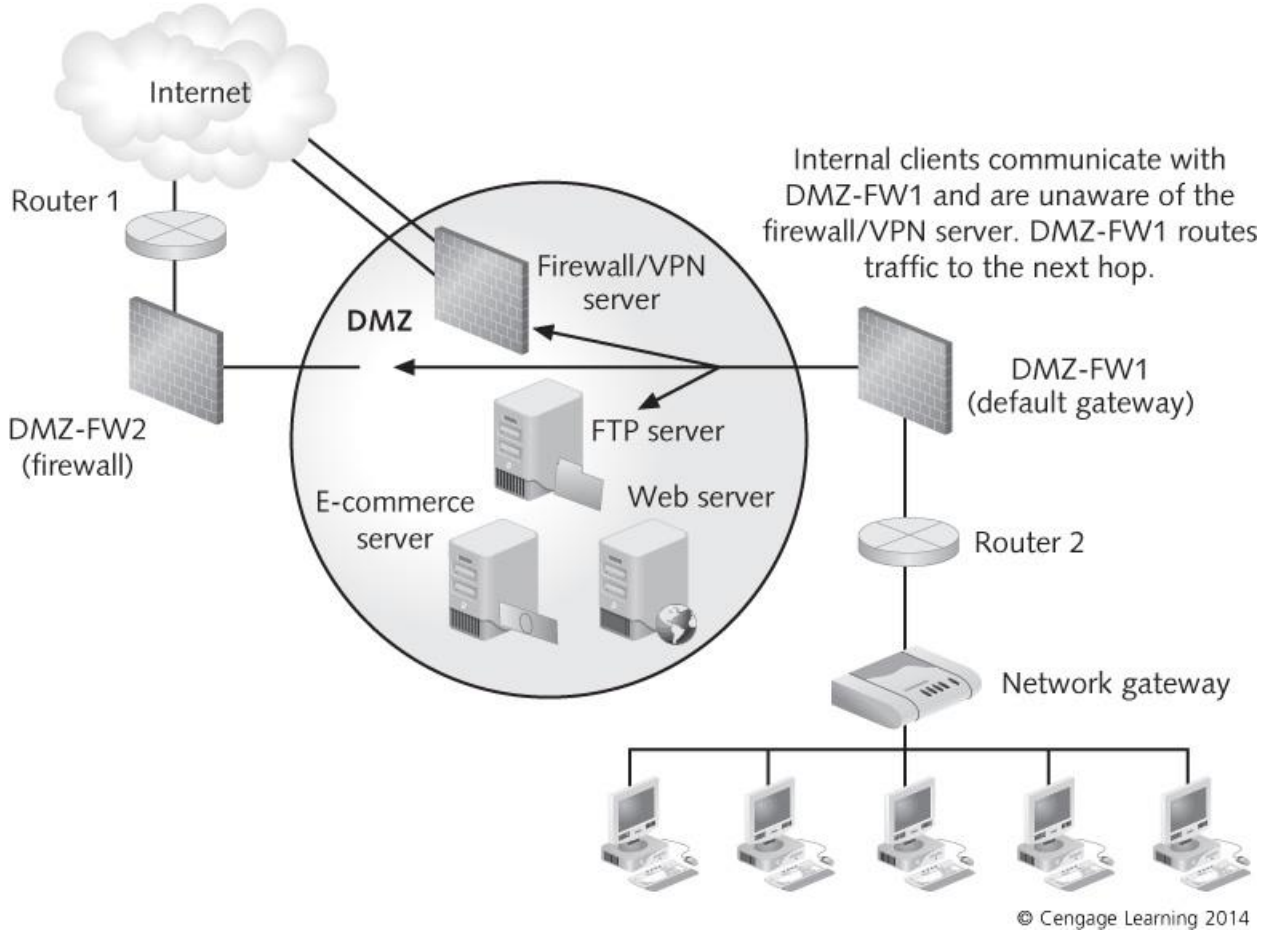

Figure 11-17 The VPN server parallel to a firewall

Using VPNs with Firewalls, Part 4

- Set up VPN server behind the firewall connected to the internal network
  - Advantages
    - VPN server is completely protected from the Internet
    - Firewall is the only device controlling access
    - VPN traffic restrictions are configured on VPN server
  - Disadvantages
    - VPN traffic must travel through the firewall
    - Firewall must handle VPN traffic
    - Firewall might not know what to do with IP protocols other than ICMP, TCP, and UDP

© Cengage Learning 2014

The VPN Server Behind a Firewall

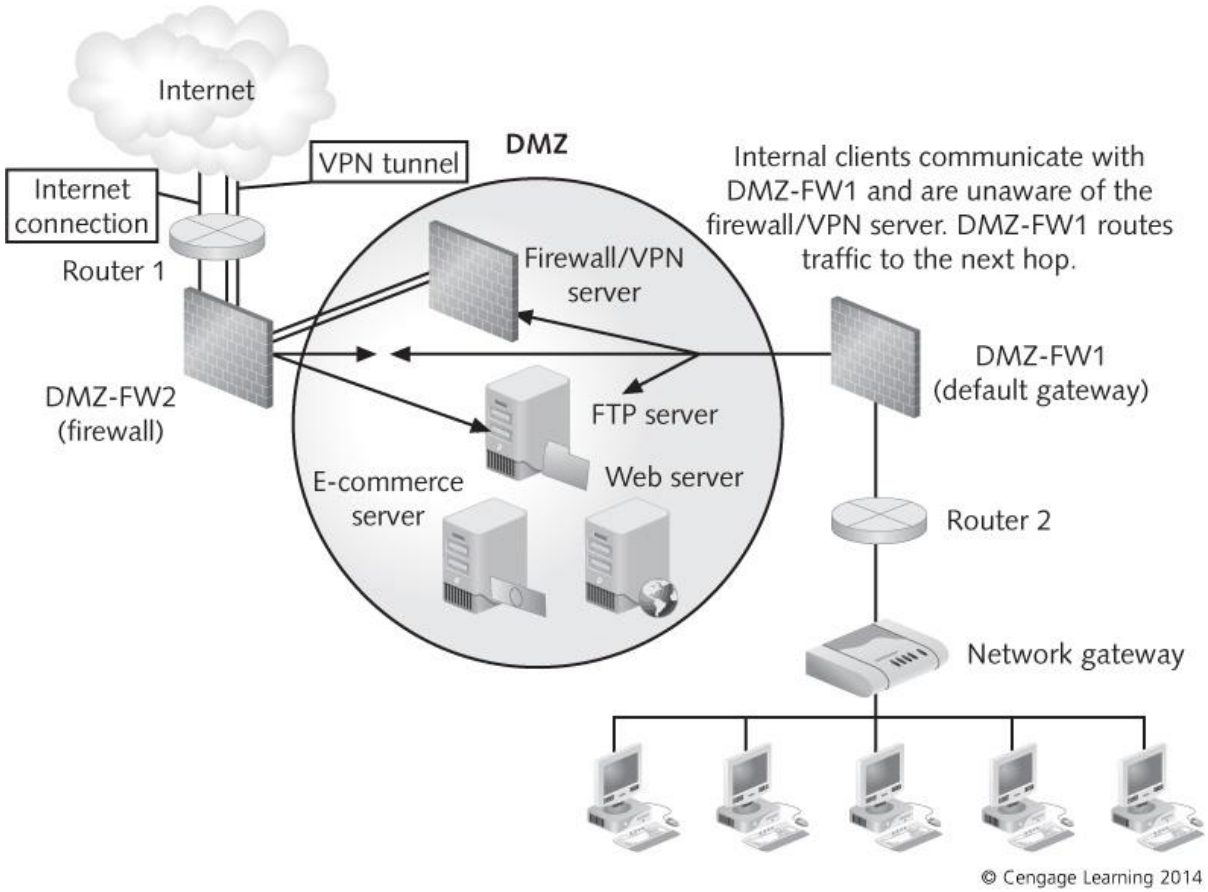

Figure 11-18 The VPN server behind a firewall

Adjusting Packet-Filtering Rules for VPNs

- Perimeter firewall filters packets VPN sends or receives using rules
- Packet filtering is based on header fields of inbound and outbound packets
- IP packet header fields used by packet filtering
  - Source address
  - Destination address
  - Protocol identifier
- You can conduct packet filtering based on any or all of these header fields

© Cengage Learning 2014

PPTP Filters

- PPTP - First widely supported VPN protocol
  - Supports legacy authentication methods
  - Does not require a PKI
  - Might be only option when VPN connections pass through NAT
  - PPTP uses two protocols
    - TCP
    - GRE

Rule	Source IP	Destination IP	Protocol	Source port	Destination port	Action
1	Any	205.43.1.78	TCP	Any	1723	Allow
2	Any	205.43.1.78	Protocol ID 47	Any	Any	Allow

Table 11-3 PPTP packet-filtering rules

© Cengage Learning 2014

L2TP and IPsec Filters

- Need to set up rules that permit IPsec traffic
  - IKE uses protocol ID 171 and UDP on port 500
  - ESP uses protocol ID 50
  - AH uses protocol ID 51

Rule	Source IP	Destination IP	Protocol	Transport protocol	Source port	Destination port	Action
1	Any	205.43.1.78	IKE	UDP	500	500	Allow
2	Any	205.43.1.78	ESP	Protocol ID 50	Any	Any	Allow
3	Any	205.43.1.78	AH	Protocol ID 51	Any	Any	Allow

Table 11-4 L2TP packet-filtering rules

© Cengage Learning 2014

Ensuring Client Security

- Several ways to increase VPN client security
- Split tunneling
  - Describes multiple paths
  - One path goes to the VPN server and is secured
  - Another unauthorized and unsecured path permits users to connect to the Internet
    - While still connected to the corporate VPN
  - Leaves the VPN server and internal LAN vulnerable to attack

© Cengage Learning 2014

Split Tunneling

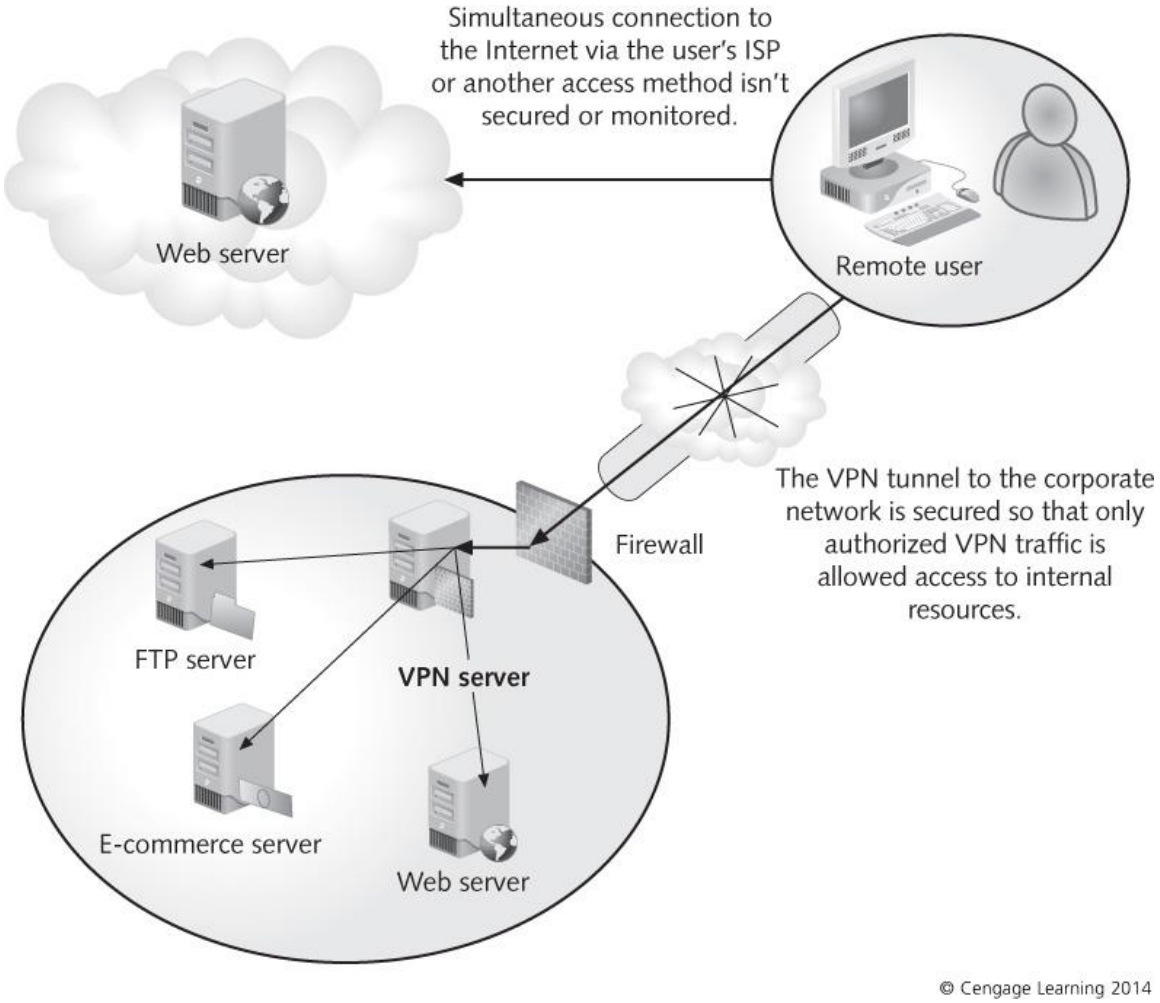

Figure 11-19 Split tunneling introduces a vulnerability

Auditing VPNs and Setting VPN Policies

- VPN endpoints are as vulnerable as internal network computers
  - Endpoints should also use antivirus software and personal firewalls
- Measures to mitigate these risks:
  - Including VPN policies in security policy
  - Using VPN quarantine procedures
  - Logging VPN connections
  - Auditing remote access activity logs

© Cengage Learning 2014

Using VPN Quarantine

- A quarantine network – segment of network with limited access to resources
  - Used for untrusted clients
- VPN quarantine – created to address problem of remote clients not meeting an organization's security standards
- Clients are subjected to preconnection and postconnection checks
  - Checks can examine service pack version, software update status, and whether antivirus programs or personal firewalls are running

© Cengage Learning 2014

Logging VPN Activity

- In a Microsoft network, Routing and Remote Access Services (RRAS) server can log events
  - Records them in the server's System, Security, and Application logs
  - Can view using Event Viewer
- The RRAS server that hosts VPN services has additional logging capabilities
  - Might need to enable Windows Authentication and Windows Accounting to configure what to log
- Windows provides support for RADIUS-based authentication and accounting logging

© Cengage Learning 2014

Auditing Compliance with VPN Policies

- Remote access policies should be defined for different levels of restriction
  - Such as what time of day access is allowed
  - Might want to have tighter controls for business partners than for company employees
- Should audit these policies to confirm enforcement and compliance
- Test each client that will connect to the network to ensure smooth operation and help prevent security threats

© Cengage Learning 2014

Guidelines for VPN Policies

- Incorporate best practices into remote access and VPN policy (see text pages 420-421 for full list):
  - Plan the most secure deployment possible
  - Use strong authentication methods
  - Require adequate password strength
  - Remote server should use DHCP to assign addresses to remote clients
  - Log remote connections and use a centralized database for storing log files
  - Use VPN quarantine procedures
  - Disable public peer-to-peer (P2P) file-sharing

© Cengage Learning 2014

Summary, Part 1

- A VPN uses encryption, encapsulation, and authentication to permit secure communications to travel over an unsecure medium
- VPNs are created by hardware or software components at each end of the connection
- Analysis of business needs is an important first step in deploying VPNs
- A VPN's three core activities are encapsulation, encryption, and authentication
- Tunneling protocols are associated with specific cryptographic methods

© Cengage Learning 2014

Summary, Part 2

- Authentication methods used are dependent on the VPN type
- VPNs can use a mesh, star, or hybrid topology
- Packet-filtering rule sets must be configured to allow VPN traffic, except when a VPN endpoint is placed parallel to a firewall
- VPNS must be managed in accordance with security policies

© Cengage Learning 2014